

VOLUME 5 OF 6

Economic Security: FinOps, Autonomous Commerce & Post-Quantum

Agent Cost Governance, Delegated Spending and Payment Mandates, and Quantum-Ready Cryptographic Architecture

Document Code: EASA-05

Version: 1.0

Date: June 2026

Scope: Domains 15, 16 & 21

Enterprise Agentic AI Security Architect (2026–2030) Master Research Program

Table of Contents

Executive Summary

This volume covers a category of risk that does not fit neatly into either traditional cybersecurity or traditional financial controls: an autonomous agent's ability to consume budget, and increasingly to spend real money, at a velocity no human approval workflow was designed for. A misconfigured agent in an infinite tool-call loop is not just a reliability incident (Volume 4) — it is a financial incident, potentially a large one, measured in minutes rather than the days or weeks a traditional procurement-fraud control was built to catch. And as the industry's payment infrastructure for agents — principally Google's Agent Payments Protocol (AP2), now contributed to the FIDO Alliance for standards-track governance — moves from pilot to production, the same agents are beginning to hold delegated authority to actually move money, not just request that a human move it.

The third domain in this volume, post-quantum readiness, sits alongside FinOps and commerce for a specific reason: the cryptographic identity and payment-mandate infrastructure this entire program is built on (SPIFFE certificates, signed Agent Cards, payment mandates) is exactly the kind of long-lived, high-value cryptographic material that harvest-now-decrypt-later attacks target, and agent infrastructure being built today will still be in service well past the timelines NIST and the NSA have set for deprecating classical algorithms.

Domain 15 — Agent FinOps & Economic Security

15.1 Threat Landscape: Budget and Cost as an Attack Surface

- **Budget Exhaustion Attacks** — an attacker (external or an internal compromised agent) deliberately drives an agent or agent fleet to consume its allocated compute/API budget, either to deny service to legitimate use or as a denial-of-wallet attack against the enterprise directly. The A2A protocol's historical default of unauthenticated endpoints (Volume 2, Domain 6) is a direct enabler here: an unauthenticated A2A endpoint can be assigned unlimited resource-heavy tasks by any caller, draining budget with no transaction ever reaching a human approval gate.
- **Cost Amplification Attacks** — an attacker exploits a multi-agent delegation chain so that a single low-cost triggering action fans out into many expensive downstream calls — a single poisoned input causing a cascading failure (ASI08, Volume 3) that is also, simultaneously, a cost-amplification event.
- **Autonomous Spending Risks** — as agents gain delegated payment authority via AP2 and similar protocols, the threat model expands from "the agent wasted compute budget" to "the agent authorized an unauthorized real-world financial transaction" — a materially different risk category requiring materially different controls, covered in Domain 16.
- **Agent Cost Governance gaps** — most organizations deploying agents in 2026 have observability into token and API cost (Volume 4, Domain 10) but lack the governance layer that ties cost anomalies to the same kill-switch and policy-enforcement infrastructure used for security incidents — meaning a runaway-cost event and a security incident are detected by different teams, on different dashboards, with different response playbooks, even though the underlying control (stop this agent now) is identical.

15.2 Agent FinOps Platform — Design Specification

The architecture this program specifies treats cost governance as a first-class policy dimension enforced at the same control point as security policy, not as a separate, downstream reporting function reconciled at month-end.

Component	Function	Integration Point
Per-agent budget envelope	Hard ceiling on spend (compute, API, and — where applicable — real-money) assigned at agent provisioning, tied to autonomy level (Domain 14, Volume 3)	Enforced at the policy engine (Cedar/OPA) alongside security authorization, not in a separate billing system
Real-time spend tracking	Continuous, sub-minute-latency tracking of consumption against budget envelope per agent, per task, per session	Fed from the same trace/telemetry stream used by the AI SOC (Volume 4, Domain 10)
Anomaly detection on spend velocity	Statistical and rule-based detection of spend-rate anomalies (a 10x normal burn rate in five minutes is a signal regardless of whether any individual action looks malicious)	Correlated with AI SOC detection logic — a spend anomaly should trigger the same investigation workflow as a security anomaly
Automatic circuit breakers	Budget envelope breach triggers automatic task suspension, not just an alert; tied to the kill-switch framework (Domain 14, Volume 3)	Same revocation mechanism as a security-triggered kill switch — credential/SVID revocation, not a soft

Component	Function	Integration Point
		"please stop" signal to the agent
Cost-per-outcome reporting	Cost normalized against the ARE reliability metric "cost-per-successful-task" (Volume 4, Domain 19.1), not raw spend alone	Feeds both FinOps reporting and the reliability error-budget calculation — connecting cost directly to whether the spend produced value

Design principle: one circuit breaker, two trigger sources

Build a single kill-switch and circuit-breaker mechanism that can be triggered either by security policy violation or by budget-envelope breach, rather than building two separate emergency-stop systems owned by two different teams. In practice the two trigger sources are correlated more often than not — runaway cost is frequently the first observable symptom of a cascading failure or a compromised agent, well before a security-specific signal fires.

Domain 16 — Autonomous Commerce Security

Autonomous commerce — agents that can browse, select, negotiate, and complete purchases or payments on a human's or organization's behalf — moved from demonstration to standards-track infrastructure with the release of Google's Agent Payments Protocol (AP2) in September 2025 and its subsequent contribution to the FIDO Alliance for industry-wide standards governance. This is the clearest signal yet that autonomous commerce is being treated by the industry as production infrastructure requiring the same rigor as existing payment rails, not as an experimental feature.

16.1 AP2 Architecture and Trust Model

AP2 addresses a structural problem traditional payment APIs were never designed for: they assume an explicit, real-time human authorization at the moment of transaction, which does not hold when an agent is acting on delegated authority, potentially asynchronously, on a task a human approved in general terms some time earlier. AP2's answer is to make consent and intent cryptographically verifiable and explicit at each stage of the transaction, rather than inferred from the fact that an authenticated session initiated the request.

AP2 Concept	Function	Security Property It Provides
Mandates (Intent / Cart)	Cryptographically signed documents capturing what the user authorized — an Intent Mandate for general authorization ("book me a flight under \$500") and a Cart Mandate for the specific transaction the agent assembled before execution	Verifiable, non-repudiable proof of what was actually authorized, closing the gap between general delegation and specific action
Role separation	Distinct roles (the user's Shopping Agent, the merchant's Credential Provider, the payment processor) such that no single role sees more than it needs — the Shopping Agent never sees raw payment credentials, for example	Limits blast radius of any single role's compromise; directly analogous to the tool-broker credential-custody pattern in Volume 1, Domain 7.3
Verifiable settlement receipts	Deterministic, auditable proof that a transaction settled as authorized	Supports dispute resolution and regulatory audit without relying on trust in any single party's transaction log
Per-task spend caps	Hard limits scoped to the specific delegated task, independent of the agent's broader FinOps budget envelope (Domain 15)	A second, transaction-specific control layer on top of the general budget-governance layer — defense in depth for spending authority specifically

Independent security analysis of AP2 reports a meaningful fraud-rate improvement over API-centric agent payment integrations — base fraud rates around 2.1% for conventional API-based agent payment flows versus approximately 1.15% under AP2's verifiable-intent model, with the largest improvement specifically in tampering-related fraud, attributed to the mandate-signing mechanism making transaction tampering cryptographically detectable rather than merely procedurally discouraged.

16.2 Demonstrated Attack Surface: Prompt Injection Against Payment Agents

Published red-team research targeting AP2 specifically via prompt injection confirms what this program's cognitive-security domain (Volume 4, Domain 18) would predict: a payment protocol's cryptographic guarantees protect the integrity of a mandate once it is signed, but do nothing to prevent an agent from being manipulated, via prompt injection in content it processes, into forming and signing a mandate it should never have formed in the first place. The cryptography is sound; the upstream goal-hijack risk (ASIO1) is unchanged by it. This is the single most important architectural lesson in this domain: a verifiable-payment protocol secures the transaction, not the decision to transact, and the cognitive-security and Least Agency controls from earlier volumes remain fully necessary even after a strong payment protocol like AP2 is adopted.

16.3 Enterprise Autonomous Commerce Security Architecture

1. Delegated spending authority is scoped identically to the autonomy-level taxonomy (Domain 14, Volume 3) — an L1 agent requires per-transaction human approval regardless of AP2 mandate signing; only L3+ agents should hold standing delegated payment authority, and even then bounded by per-task spend caps.
2. Wallet-based transactions and stored payment credentials are never held directly by the purchasing agent — consistent with the tool-broker credential-custody architecture (Volume 1, Domain 7.3), the agent requests a scoped, single-use payment token from a credential broker rather than holding reusable payment credentials in its own context or memory.
3. Procurement agents operating against external vendor or marketplace A2A endpoints require the same Agent Card signature verification and trust-broker evaluation specified for any external A2A counterparty (Volume 2, Domain 6.3) before any mandate is formed, not just before settlement.
4. Every formed Cart Mandate is logged to the immutable audit trail (Volume 1, Domain 4) with full provenance of the inputs (which documents, search results, or tool outputs influenced the purchasing decision), specifically to support post-incident forensic reconstruction of how a malicious mandate was formed if cognitive-security controls fail.
5. Spend caps under Domain 15's FinOps envelope and AP2's per-task mandate caps are treated as independent, redundant controls — a misconfiguration in one should not silently remove the protection of the other.

Domain 21 — Quantum-Ready Agent Security

Post-quantum cryptography belongs in an agentic security program for a reason specific to this domain, not as a generic cryptography-hygiene item: the identity and trust infrastructure specified throughout this program — SPIFFE SVIDs, signed Agent Cards, AP2 mandates — is precisely the category of cryptographic material with long operational lifetimes and high replay/forgery value that harvest-now-decrypt-later attacks are designed to exploit. An adversary recording today's signed Agent Card exchanges or mandate signatures, intending to forge or decrypt them once cryptographically relevant quantum computers exist, is a realistic threat model for infrastructure this program expects to remain in service for years.

21.1 NIST Post-Quantum Standards — Current Status

NIST finalized its first three post-quantum cryptographic standards in August 2024, concluding an eight-year evaluation process, and the regulatory and infrastructure environment has moved decisively since:

Standard	Algorithm	Function	Status, mid-2026
FIPS 203	ML-KEM (formerly Kyber)	Lattice-based key encapsulation (key exchange)	Finalized; already deployed in hybrid X25519+ML-KEM-768 configurations in production browsers and major CDNs; integrated into OpenSSL 3.5
FIPS 204	ML-DSA (formerly Dilithium)	Lattice-based digital signatures	Finalized; the primary candidate for signing agent identity credentials and payment mandates going forward
FIPS 205	SLH-DSA (formerly SPHINCS+)	Hash-based digital signatures (stateless, conservative fallback)	Finalized; relies solely on hash-function security rather than lattice assumptions — recommended as a crypto-agility fallback alongside ML-DSA rather than a primary scheme, given its substantially larger signature sizes
HQC	Hamming Quasi-Cyclic	Alternative, non-lattice key encapsulation mechanism	Selected March 2025 as a structurally independent backup to ML-KEM; draft publication expected 2026, full standardization expected 2027

NIST's draft guidance (IR 8547) calls for deprecating quantum-vulnerable algorithms — RSA, ECDSA, EdDSA, DH, and ECDH — by 2030, with full retirement by 2035; the NSA has separately mandated post-quantum capability for national security systems by 2025, moving to exclusive PQC use by 2035. These are not distant timelines relative to the operational life of identity and payment infrastructure being architected now.

21.2 Practical Constraints

Post-quantum migration is not a drop-in algorithm swap, and agent infrastructure has specific exposure to the practical constraints involved. ML-KEM operations on resource-constrained edge or embedded inference hardware run roughly two orders of magnitude slower than on server-class CPUs, and memory requirements

increase two-to-fivefold compared to classical algorithms — directly relevant for any agent runtime architecture (Volume 1, Domain 7) deployed to edge inference or constrained sandboxed environments rather than full server-class compute. Signature sizes also grow substantially: ML-DSA signatures run roughly 2,400–4,600 bytes and SLH-DSA signatures 7,800–49,900 bytes, versus a few hundred bytes for classical ECDSA — a material consideration for any high-frequency signing operation, such as per-task mandate signing under AP2 (Domain 16) or per-request SPIFFE SVID issuance at agent-population scale (Volume 2, Domain 2).

Crypto-agility — the capability to rotate cryptographic algorithms quickly without a hard-coded dependency on any single scheme — is the operational property that determines whether an organization can actually respond to a future cryptanalytic break, and is explicitly identified by current research as the binding constraint, more than any single algorithm choice. Protocols and infrastructure that hard-code a specific algorithm, or that require firmware-level updates to change it, cannot pivot within any relevant response timescale.

21.3 Post-Quantum Agent Fabric — Design Specification

1. Hybrid cryptography as the default, not pure post-quantum — combine classical (X25519/ECDSA) and post-quantum (ML-KEM/ML-DSA) algorithms in every new identity and transport implementation, following the same hybrid pattern already in production for TLS; this hedges against both a cryptanalytic break in the new PQC algorithms (still a less battle-tested mathematical foundation) and the known vulnerability of the classical algorithms to a future quantum adversary.
2. PQC-ready identity substrate — extend the SPIFFE/SPIRE trust domain (Volume 2, Domain 2) to issue hybrid-signed SVIDs as the PQC ecosystem in SPIFFE's own tooling matures, rather than waiting for a wholesale identity-infrastructure replacement once quantum risk becomes acute.
3. PQC-ready payment mandates — track the FIDO Alliance Payments Technical Working Group's post-quantum profile for AP2 directly (the working group is, as of mid-2026, actively scoping this), and plan for ML-DSA-signed mandates as the natural successor to current classical signing schemes given the multi-year operational lifetime of payment-authorization infrastructure.
4. Hybrid TLS everywhere agents communicate — apply hybrid X25519+ML-KEM TLS configurations to all MCP and A2A gateway transport (Volume 2, Domains 5 and 6) as the default for any new gateway deployment, consistent with the pattern already standard in major browsers and CDNs.
5. Crypto-agility as an explicit architecture requirement — any component issuing or verifying agent identity, signing Agent Cards, or signing payment mandates must support algorithm negotiation/rotation without a hard dependency baked into firmware or an unupgradable protocol version, evaluated as a first-class procurement and architecture-review criterion alongside the functional requirements for any new identity, MCP, or A2A infrastructure component.

Where this sits on the priority list

Post-quantum readiness is a multi-year migration, not a 2026 deliverable, and should not compete for budget against the identity, MCP, A2A, and governance priorities in Volumes 2 and 3 that address active, currently-exploited risk. The correct near-term action is architectural: ensure every new identity, MCP, A2A, and payment-mandate component procured or built from this point forward supports crypto-agility and hybrid algorithms, so the eventual PQC migration is a configuration change rather than a forklift replacement of infrastructure being built today.